

SIMATS ENGINEERING

ASSESSMENT TOOL 2

COURSE NAME: Ethical Hacking **COURSE CODE:** ITA14

COURSE OUTCOME COVERED

CO4: Implement network security testing methods by performing web server attacks, analyzing web application vulnerabilities, and assessing wireless network security using Kali Linux.

QUESTIONS: 01

Total Marks: 100

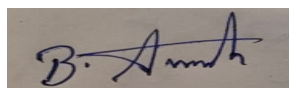
VULNERABILITY ASSESSMENT REPORT

Code of Conduct:

I Avinash B (192511193)(Name / Reg No) certify that this submission is my original work and that I have adhered to the guidelines specified for this assessment.

I understand that any violation of academic integrity rules will result in disciplinary action.

Signature of the student:

A handwritten signature in black ink, appearing to read 'B. Avinash', is written on a light-colored rectangular background.

Question 1 – TJX Companies Wireless Network Breach, 2005–2007

1. Incident Background and Technical Understanding

TJX Companies experienced a major payment-card data breach after attackers obtained unauthorized wireless access to its retail network. The supplied case states that TJX used WEP while transitioning to WPA and lacked adequate controls to restrict wireless access. The incident demonstrated weaknesses in obsolete encryption, monitoring, network segmentation, and protection of sensitive payment data.

2. Identification of Wireless Vulnerabilities

- Use of WEP provided weak wireless confidentiality compared with modern WPA2/WPA3 protection.
- Wireless access controls were insufficient to restrict unauthorized devices and users.
- Inadequate network segmentation increased the chance that wireless compromise could reach sensitive payment systems.
- Insufficient monitoring reduced the ability to detect suspicious wireless activity quickly.
- Sensitive payment information required stronger protection and compliance-oriented controls.
- Authentication and access control needed to be stronger than relying on weak/legacy wireless security.

3. Risk, Impact, and Root-Cause Analysis

The primary attack vector was unauthorized wireless access followed by movement toward systems containing payment information. The likelihood was high because legacy encryption and weak access restrictions make wireless compromise easier. The consequences included confidentiality loss, possible payment-data exposure, operational disruption, financial losses, privacy consequences, legal/compliance exposure, and reputational damage. Overall risk is HIGH.

Root cause: The root cause was a combination of legacy wireless encryption, insufficient wireless access restriction, weak segmentation, and inadequate monitoring. Security controls were not sufficiently aligned with the sensitivity of payment-card data.

Impact: High likelihood and high impact due to access to payment-related systems.

4. Security Recommendations and Mitigation Measures

1. Replace WEP with WPA2-Enterprise or WPA3-Enterprise, using strong cryptographic protection.
2. Implement enterprise authentication such as 802.1X with centrally managed user/device credentials.
3. Separate wireless client networks from point-of-sale and payment-card environments using VLANs and firewalls.
4. Deploy rogue-access-point and wireless intrusion detection to identify unauthorized devices and suspicious associations.
5. Apply PCI DSS controls appropriate to payment-card environments, including access control, logging, monitoring, and protection of cardholder data.
6. Use least privilege and deny-by-default firewall rules between wireless, corporate, and payment networks.
7. Continuously monitor authentication failures, unusual wireless associations, lateral movement, and access to sensitive systems.
8. Regularly assess wireless configurations and remove legacy protocols and unused access points.

5. Evidence and Risk-Rating Summary

Risk Area	Finding	Risk
Encryption	WEP/legacy protection was identified in the case	HIGH

Network segmentation	Wireless access was not adequately isolated from sensitive systems	HIGH
Monitoring	Insufficient monitoring could delay detection	HIGH
Payment data	Sensitive payment information required stronger protection	HIGH
Authentication/access	Wireless access restriction was inadequate	HIGH

Overall risk rating: HIGH

Question 2 – Lowe’s Wireless Network Intrusion, 2003

1. Incident Background and Technical Understanding

In 2003, attackers compromised the wireless network of a Lowe’s retail store in Southfield, Michigan. According to the supplied case, the compromised wireless connection provided access to central systems and other retail locations, and attackers attempted to install software intended to capture customers’ credit-card information.

2. Identification of Wireless Vulnerabilities

- Wireless access was able to reach broader corporate systems instead of being strongly isolated.
- Authentication and wireless access controls were insufficient to prevent the local compromise.
- Firewall controls did not adequately restrict movement from the wireless network to internal systems.
- Point-of-sale systems were not sufficiently segmented from the compromised wireless environment.
- Intrusion detection was insufficient to identify or stop suspicious activity quickly.
- Centralized access management needed stronger control over users, devices, and network privileges.

3. Risk, Impact, and Root-Cause Analysis

The critical attack path was local wireless compromise → internal corporate access → attempted access to payment-related systems. A local compromise therefore had potentially nationwide consequences. Risk is HIGH because the attack could affect confidentiality, integrity, and availability of corporate and payment systems.

Root cause: The root cause was inadequate wireless isolation and excessive trust between the local wireless environment and internal corporate infrastructure, combined with insufficient firewalling, segmentation, intrusion detection, and centralized access control.

Impact: High because a local wireless compromise could become a broader corporate compromise.

4. Security Recommendations and Mitigation Measures

9. Place wireless clients in dedicated VLANs and security zones separated from corporate and point-of-sale networks.
10. Use firewalls with explicit allow rules between wireless, store, corporate, and payment networks.
11. Deploy strong enterprise authentication with individual identities and device controls.
12. Apply least-privilege network access so a wireless client cannot automatically reach central systems.
13. Deploy network intrusion detection/prevention and monitor unusual connections from wireless segments.
14. Centralize identity, authentication, authorization, and logging so access can be reviewed and revoked quickly.
15. Protect point-of-sale systems with dedicated segmentation and strict administrative access.
16. Perform periodic wireless and firewall configuration reviews and penetration testing in an authorized environment.

5. Evidence and Risk-Rating Summary

Risk Area	Finding	Risk
Wireless isolation	Compromised wireless access reached wider systems	HIGH
Firewall controls	Internal reachability needed stronger restrictions	HIGH
POS segmentation	Payment systems needed	HIGH

	dedicated isolation	
Intrusion detection	Suspicious activity required earlier detection	HIGH
Central access management	Access needed centralized control and accountability	HIGH

Overall risk rating: HIGH

Question 3 – Firesheep and Public Wi-Fi Session Hijacking, 2010

1. Incident Background and Technical Understanding

The supplied case explains that the Firesheep browser extension demonstrated how attackers on the same open wireless network could capture unencrypted session cookies and impersonate authenticated users. It highlighted the weakness of protecting only the login page while later session traffic remained unencrypted.

2. Identification of Wireless Vulnerabilities

- Open public Wi-Fi allowed nearby users to observe network traffic.
- Unencrypted session cookies could be captured and reused for session hijacking.
- Partial HTTPS protection was insufficient because later authenticated traffic could remain exposed.
- Lack of HSTS could allow users to fall back to insecure HTTP connections.
- Users on a shared wireless network were not sufficiently isolated from one another.
- Users needed stronger security awareness regarding open Wi-Fi and session protection.

3. Risk, Impact, and Root-Cause Analysis

The main attack vector was interception of unencrypted session information on a shared network. The attacker did not necessarily need to know the victim's password; a stolen active session cookie could be sufficient to impersonate the authenticated user. Risk is HIGH where sensitive web accounts are used over an insecure network.

Root cause: The root cause was failure to enforce end-to-end encrypted web sessions and insufficient protection of session cookies on an untrusted wireless network.

Impact: High for accounts carrying personal, financial, or organizational information.

4. Security Recommendations and Mitigation Measures

17. Enforce HTTPS for the entire website, not only the login page.
18. Enable HSTS so browsers are instructed to use HTTPS consistently.
19. Use Secure and HttpOnly cookie attributes and appropriate SameSite settings for session cookies.
20. Use modern TLS configurations and avoid insecure HTTP endpoints.
21. Provide client isolation on public Wi-Fi so connected users cannot directly communicate with one another where feasible.
22. Recommend VPN use on untrusted networks, especially for sensitive work.
23. Use strong authentication and MFA to reduce the value of stolen credentials and sessions.
24. Educate users not to trust open Wi-Fi and to pay attention to browser certificate/security warnings.

5. Evidence and Risk-Rating Summary

Risk Area	Finding	Risk
Session confidentiality	Unencrypted cookies could be captured	HIGH
HTTPS enforcement	Partial encryption left later traffic exposed	HIGH
HSTS	Without HSTS, downgrade to HTTP could be possible	HIGH
Client isolation	Shared Wi-Fi increased local attack exposure	MEDIUM-HIGH
User awareness	Users could unknowingly connect/use insecure sessions	MEDIUM

Overall risk rating: HIGH

Question 4 – DarkHotel Attacks Through Hotel Wi-Fi Networks

1. Incident Background and Technical Understanding

The supplied case describes DarkHotel as a campaign targeting business executives and government officials through compromised hotel networks. Selected guests were shown fraudulent software-update prompts that delivered malware. The case highlights risks from third-party Wi-Fi management, captive portals, insecure update mechanisms, and insufficient guest-network monitoring.

2. Identification of Wireless Vulnerabilities

- Compromised or poorly managed hotel Wi-Fi could be used as an attack platform.
- Captive portals could be abused if their security and integrity were weak.
- DNS integrity was important because manipulated DNS could redirect users to malicious destinations.
- Guest networks required strong segmentation from hotel administrative and privileged systems.
- Third-party access and management created additional trust and supply-chain risks.
- Fraudulent software-update prompts could exploit weak update verification.
- Insufficient monitoring could allow targeted malware delivery to go unnoticed.

3. Risk, Impact, and Root-Cause Analysis

The attack chain could involve compromised hotel infrastructure, manipulation of network services or portals, delivery of fraudulent update prompts, and malware installation on selected guests' devices. High-value executives and officials increase the impact of successful compromise. Risk is HIGH.

Root cause: The root cause was insufficient trust-boundary separation and monitoring across guest Wi-Fi, captive-portal infrastructure, third-party administration, DNS, and privileged hotel systems, combined with weak verification of software updates.

Impact: High because targeted compromise can affect privileged users and sensitive organizational information.

4. Security Recommendations and Mitigation Measures

25. Separate guest Wi-Fi completely from hotel administrative, payment, staff, and privileged management networks.
26. Secure captive portals with HTTPS, strong administrative authentication, secure session handling, and change monitoring.
27. Protect DNS using secure configuration and monitoring; investigate unexpected DNS changes.
28. Restrict third-party administrative access using least privilege, MFA, time limits, and logging.
29. Require digitally signed software updates and verify signatures before installation.
30. Deploy endpoint protection and malware detection on hotel-managed devices.
31. Use wireless and network monitoring to detect rogue access points, unusual DNS activity, and suspicious traffic.
32. Maintain incident-response procedures for suspected compromise and notify affected users appropriately.

5. Evidence and Risk-Rating Summary

Risk Area	Finding	Risk
Guest segmentation	Guest access must not reach privileged hotel networks	HIGH
Captive portal	Portal manipulation could enable malicious delivery	HIGH

DNS integrity	DNS manipulation can redirect users	HIGH
Third-party access	External management increases attack surface	HIGH
Update security	Fraudulent update prompts can deliver malware	HIGH

Overall risk rating: HIGH

Question 5 – Marriott Wi-Fi Deauthentication Incident, 2014

1. Incident Background and Technical Understanding

The supplied case states that the U.S. Federal Communications Commission investigated Marriott after equipment was used to send Wi-Fi deauthentication messages that prevented guests from using personal hotspots. Marriott agreed to pay a civil penalty of \$600,000. The incident demonstrated that unprotected wireless management frames can be misused to disconnect legitimate users.

2. Identification of Wireless Vulnerabilities

- Unprotected 802.11 management frames can permit deauthentication/disassociation abuse.
- Wireless availability can be disrupted even without stealing data.
- Weak protection of management frames increases susceptibility to wireless denial-of-service activity.
- Insufficient wireless intrusion detection may delay identification of abnormal deauthentication activity.
- Acceptable-use policies must clearly define permitted wireless interference and security practices.
- Failure to control such activity can create legal and regulatory consequences.

3. Risk, Impact, and Root-Cause Analysis

The principal risk is availability. Repeated deauthentication can disconnect legitimate wireless clients and interfere with their connectivity. In this case, the activity also created legal and regulatory consequences. Risk is HIGH when wireless service is critical and deliberate interference affects users.

Root cause: The root cause was inadequate protection/detection against misuse of wireless management frames and insufficient controls around acceptable wireless interference. The case also demonstrates that technical actions affecting users can create legal and regulatory risk.

Impact: High because availability disruption combined with regulatory/legal exposure can be significant.

4. Security Recommendations and Mitigation Measures

33. Use Protected Management Frames (PMF/802.11w) where supported and required by the wireless security design.
34. Adopt WPA3 configurations that support stronger management-frame protection and modern authentication.
35. Deploy wireless intrusion detection/prevention to detect abnormal deauthentication and disassociation patterns.
36. Establish an acceptable-use policy prohibiting unauthorized wireless interference.
37. Monitor access points for unusual management-frame behavior and investigate repeated client disconnects.
38. Use incident-response procedures that preserve logs and wireless evidence.
39. Train wireless administrators so troubleshooting does not cross into prohibited interference.
40. Review legal and regulatory requirements before deploying any control that affects client connectivity.

5. Evidence and Risk-Rating Summary

Risk Area	Finding	Risk
Management frames	Unprotected frames could be abused for forced disconnects	HIGH
Availability	Users could lose wireless connectivity	HIGH
Detection	Wireless IDS can identify abnormal patterns	MEDIUM-HIGH
Policy	Unauthorized interference needs	HIGH

	explicit prohibition	
Legal exposure	The case involved a civil penalty	HIGH

Overall risk rating: HIGH

Question 6 – Fake Wi-Fi Networks at the Republican National Convention, 2016

1. Incident Background and Technical Understanding

The supplied case states that a security experiment established fake open wireless networks near the event venue. Approximately 1,200 users connected within one day. The experiment demonstrated how easily users could trust unknown network names and expose device or identity information.

2. Identification of Wireless Vulnerabilities

- Users may trust an SSID merely because its name appears legitimate.
- Automatic Wi-Fi reconnection can cause devices to connect to previously known or similar networks.
- Open Wi-Fi lacks strong network-level authentication.
- Captive portals can be imitated by malicious access points.
- Users may ignore certificate/security warnings.
- Lack of VPN enforcement increases exposure on untrusted networks.
- Large public events create a high-density environment where rogue access points can attract many users.

3. Risk, Impact, and Root-Cause Analysis

The attack vector is an evil-twin/fake access point that imitates a trusted SSID. Users who connect may expose traffic, identity information, or authentication data depending on application security. Risk is HIGH at large events because many users are mobile, hurried, and likely to trust familiar network names.

Root cause: The root cause is excessive trust in SSID names and insufficient verification of the actual network. Automatic reconnection, weak network authentication, and limited user awareness increase the likelihood of successful connection to a fake AP.

Impact: High due to large-scale user exposure and easy social trust in network names.

4. Security Recommendations and Mitigation Measures

41. Use WPA2-Enterprise/WPA3-Enterprise for managed organizational networks rather than open Wi-Fi where possible.
42. Disable automatic connection to unknown or unnecessary public networks on managed devices.
43. Use wireless monitoring to detect duplicate/evil-twin SSIDs and unauthorized access points.
44. Enforce HTTPS/TLS and teach users never to bypass certificate warnings.
45. Use VPN on untrusted networks for sensitive organizational activity.
46. Use secure captive portals and clearly communicate the official SSID and connection procedure.
47. Provide awareness training before major events and display trusted network-verification instructions.
48. For managed devices, use device certificates and centrally controlled wireless profiles.

5. Evidence and Risk-Rating Summary

Risk Area	Finding	Risk
SSID trust	Users connected to fake networks based on familiar names	HIGH
Automatic reconnection	Devices can reconnect without deliberate verification	HIGH
Evil-twin detection	Rogue AP monitoring is needed	HIGH
Certificate validation	Warnings must not be ignored	HIGH

VPN/awareness	Users need additional protection on open networks	MEDIUM-HIGH
---------------	---	-------------

Overall risk rating: HIGH

Question 7 – Wi-Fi Attacks Against Anti-Doping Officials, 2016

1. Incident Background and Technical Understanding

According to the supplied case, close-access teams targeted Wi-Fi networks used by anti-doping officials during events in Rio de Janeiro and Lausanne. Hotel Wi-Fi access was allegedly used to compromise credentials and obtain unauthorized access to sensitive anti-doping and medical information.

2. Identification of Wireless Vulnerabilities

- Hotel and event Wi-Fi were high-risk environments for credential theft.
- Weak authentication could expose accounts to compromise.
- Insufficient MFA increases the consequences of stolen credentials.
- Lack of device certificates makes device identity harder to verify.
- Endpoint security is essential because travel devices may connect to untrusted networks.
- Improper VPN configuration can expose sensitive traffic.
- Travel without clear security procedures increases the attack surface.
- Medical information requires strong confidentiality and access controls.

3. Risk, Impact, and Root-Cause Analysis

The attack vector combined physical proximity, untrusted Wi-Fi, credential compromise, and access to sensitive information. The impact is especially serious because the case concerns anti-doping and medical information. Risk is HIGH due to confidentiality, privacy, integrity, and reputational consequences.

Root cause: The root cause was inadequate protection of credentials and endpoints when officials used public/hotel networks, together with insufficient MFA, device identity, VPN, and travel-security controls.

Impact: High because sensitive medical and organizational information was a target.

4. Security Recommendations and Mitigation Measures

49. Require MFA for all sensitive organizational accounts, especially administrator and remote-access accounts.
50. Use strong enterprise authentication and unique user credentials; prohibit shared accounts.
51. Use device certificates or managed-device identity for organizational Wi-Fi and remote access where appropriate.
52. Require VPN with strong cryptographic protection for sensitive traffic on hotel/event Wi-Fi.
53. Harden travel devices with endpoint protection, secure configuration, patching, and centralized monitoring.
54. Apply travel-security policies covering Wi-Fi use, removable media, device handling, and incident reporting.
55. Restrict access to medical information using least privilege and role-based access control.
56. Monitor authentication anomalies such as impossible travel, repeated failures, unusual devices, and suspicious sessions.

5. Evidence and Risk-Rating Summary

Risk Area	Finding	Risk
Credentials	Hotel Wi-Fi could expose credentials	HIGH
MFA	Additional authentication reduces account-takeover risk	HIGH
Endpoint security	Travel devices are exposed to	HIGH

	untrusted networks	
VPN	Sensitive traffic requires secure transport	HIGH
Medical information	Unauthorized access creates severe privacy impact	HIGH

Overall risk rating: HIGH

Question 8 – Attempted OPCW Wi-Fi Intrusion, 2018

1. Incident Background and Technical Understanding

The supplied case states that in April 2018 Dutch authorities disrupted an attempted close-access cyber operation against the Organisation for the Prohibition of Chemical Weapons in The Hague. Equipment intended for a Wi-Fi compromise was found in a vehicle parked near the organization's premises.

2. Identification of Wireless Vulnerabilities

- Wireless signals can extend beyond the physical perimeter and can be targeted from nearby locations.
- Enterprise Wi-Fi requires strong authentication such as 802.1X.
- EAP certificate validation is important to prevent clients from trusting fraudulent authentication infrastructure.
- Rogue-device detection can identify unauthorized wireless equipment.
- Wireless intrusion prevention can detect and respond to suspicious activity.
- Physical surveillance is relevant because close-access attacks may involve equipment positioned near a facility.
- Network access control should verify device/user authorization before granting internal access.

3. Risk, Impact, and Root-Cause Analysis

The attack demonstrates that physical perimeter security does not automatically protect wireless networks because radio signals can be reached from outside the facility. A successful wireless compromise could provide an attacker with internal network access. Risk is HIGH for a security-sensitive organization.

Root cause: The root cause to be assessed is exposure of enterprise wireless services beyond the physical perimeter without sufficiently layered controls for authentication, certificate validation, rogue-device detection, physical monitoring, and network access control.

Impact: High because compromise of a sensitive organization's wireless network could expose internal systems.

4. Security Recommendations and Mitigation Measures

57. Use WPA2-Enterprise or WPA3-Enterprise with 802.1X for organizational Wi-Fi.
58. Configure EAP certificate validation correctly on clients and verify trusted certificate authorities.
59. Use strong, unique credentials and MFA where supported for administrative access.
60. Deploy wireless intrusion detection/prevention to identify rogue APs and suspicious close-access equipment.
61. Use network access control to verify authenticated users and compliant devices before granting access.
62. Conduct wireless site surveys to understand signal leakage outside the intended perimeter.
63. Combine wireless security with physical surveillance around sensitive facilities.
64. Segment wireless clients and restrict access to critical systems using firewalls and least privilege.

5. Evidence and Risk-Rating Summary

Risk Area	Finding	Risk
RF exposure	Wireless signals can be targeted outside the building	HIGH
802.1X/EAP	Strong enterprise authentication and validation are required	HIGH
Rogue devices	Unauthorized equipment needs	HIGH

	detection	
Physical security	Close-access attacks require physical monitoring	HIGH
NAC	Authenticated access should also be authorized and device-aware	HIGH

Overall risk rating: HIGH

Question 9 – Australian Airport and In-Flight Evil-Twin Case, 2024

1. Incident Background and Technical Understanding

The supplied case states that the Australian Federal Police charged a man who allegedly established fake free Wi-Fi access points that imitated legitimate networks at airports and other locations. The alleged purpose was to capture personal data from users who connected to the fraudulent access points.

2. Identification of Wireless Vulnerabilities

- SSID impersonation can make a rogue AP appear legitimate.
- Automatic connection can cause devices to join a fraudulent AP.
- Captive portals can be copied or used to collect information.
- Users may overlook certificate/security warnings.
- Passenger data may be exposed when users connect to a malicious network.
- Airports need rogue-access-point detection and a clear staff response procedure.
- Users need a reliable method to verify the official network before connecting.

3. Risk, Impact, and Root-Cause Analysis

The attack vector is an evil-twin access point positioned where many travelers expect free Wi-Fi. Successful connection can expose personal information depending on application protections and user behavior. Risk is HIGH because airports contain many users, sensitive devices, and time-pressured travelers.

Root cause: The root cause is reliance on SSID names as proof of authenticity, combined with automatic connection behavior and insufficient technical/user verification of wireless networks.

Impact: High due to high user density and the potential for personal-data exposure.

4. Security Recommendations and Mitigation Measures

- 65. Provide clearly documented official SSIDs and connection instructions through airport/airline channels.
- 66. Deploy wireless monitoring to detect unauthorized APs and duplicate SSIDs.
- 67. Disable automatic connection to public networks on managed staff devices.
- 68. Use secure captive portals with HTTPS and strong administrative access control.
- 69. Enforce TLS and never instruct users to bypass certificate warnings.
- 70. Use VPN for staff and sensitive operations on untrusted networks.
- 71. Create staff procedures for identifying, reporting, and responding to rogue APs.
- 72. Train passengers/staff to verify network names and avoid entering sensitive credentials into suspicious portals.

5. Evidence and Risk-Rating Summary

Risk Area	Finding	Risk
SSID impersonation	Fake networks can closely resemble legitimate networks	HIGH
Automatic connection	Devices may connect without careful user review	HIGH
Captive portal	Fake portals can collect information	HIGH
Rogue AP detection	Airport operators need monitoring	HIGH
User verification	Travelers need simple verification guidance	MEDIUM-HIGH

Overall risk rating: HIGH

Question 10 – Network Rail Public Wi-Fi Portal Compromise, 2024

1. Incident Background and Technical Understanding

The supplied case states that on September 25, 2024, public Wi-Fi services at 19 major UK railway stations displayed unauthorized offensive content. Reports stated that the Wi-Fi landing page was changed using a legitimate administrator account, and the affected services were suspended while the incident was investigated.

2. Identification of Wireless Vulnerabilities

- Compromise or misuse of a legitimate administrator account can bypass controls that focus only on unknown attackers.
- Privileged-access management is required to limit administrator permissions.
- MFA should protect administrative accounts.
- Captive-portal administration needs strong authentication and authorization.
- Third-party supplier access can create additional privileged-account risk.
- Logging and account monitoring are necessary to detect unauthorized administrative changes.
- Change approval and configuration management should prevent unapproved portal modifications.
- Incident response must support rapid suspension, investigation, recovery, and evidence preservation.

3. Risk, Impact, and Root-Cause Analysis

The most important attack path is misuse or compromise of a legitimate privileged account to alter a public-facing Wi-Fi portal. Because the account is legitimate, traditional perimeter controls may not identify the activity immediately. Risk is HIGH due to public exposure, reputational impact, service disruption, and the possibility of wider administrative compromise.

Root cause: The root cause to be assessed is insufficient protection and governance of privileged administrator access, including authentication, MFA, third-party access, logging, monitoring, and controlled change management.

Impact: High because privileged-account misuse can directly modify a public service and undermine trust.

4. Security Recommendations and Mitigation Measures

- 73. Apply privileged-access management with least privilege, separate administrator accounts, and controlled elevation of privileges.
- 74. Require MFA for all administrative and supplier accounts.
- 75. Use role-based access control so administrators can change only the systems necessary for their role.
- 76. Restrict third-party supplier access using approved accounts, time-bound permissions, and monitoring.
- 77. Maintain detailed immutable logs for administrator logins, configuration changes, and portal-content changes.
- 78. Use change approval and configuration-management procedures for public-facing Wi-Fi portals.
- 79. Monitor administrator behavior and generate alerts for unusual login locations, times, or configuration changes.
- 80. Maintain an incident-response playbook for portal compromise, including service suspension, credential reset, forensic preservation, and restoration from known-good configuration.

5. Evidence and Risk-Rating Summary

Risk Area	Finding	Risk
Privileged access	Legitimate admin accounts can be abused	HIGH

MFA	Administrative access requires stronger authentication	HIGH
Third-party access	Supplier accounts expand the attack surface	HIGH
Logging/monitoring	Changes must be attributable and detectable	HIGH
Change control	Public portal changes require approval	HIGH

Overall risk rating: HIGH

Overall Conclusion

The ten cases show recurring wireless-security weaknesses: legacy or weak encryption, insufficient authentication, poor network segmentation, weak management-frame protection, rogue/evil-twin access points, insecure captive portals, inadequate endpoint and session protection, excessive privileged access, insufficient monitoring, and weak security awareness. A layered approach should therefore combine WPA2/WPA3, enterprise authentication, 802.1X, certificate validation, network segmentation, firewalls, wireless intrusion detection/prevention, MFA, privileged-access management, secure HTTPS/TLS, VPNs, endpoint security, centralized logging, change control, physical security, and user awareness. These controls reduce both the likelihood of wireless compromise and the impact when an attack is attempted.

Note on Assessment Evidence

The supplied PDF provides the ten incident scenarios and the assessment criteria, including incident understanding, vulnerability identification, risk/impact/root-cause analysis, recommendations/mitigation, and report quality/evidence. [filecite\turn0file0\L19-L28](#) The case-specific questions are listed in Annexure A across the supplied document. [filecite\turn0file0\L146-L165](#) [filecite\turn0file0\L166-L185](#) [filecite\turn0file0\L186-L204](#) [filecite\turn0file0\L205-L223](#) [filecite\turn0file0\L224-L241](#)